LABORATUVAR 5 · PAKETPRO 3000 · Paketleme Makinesi

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad şerif miraç gögebakan | Grup | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	PaketPro Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1 Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

üç şarta bakarız 1. bileşen bizde var mı evet paketpro nun plc kütüphanesinde component x var 2. sürüm uyuyor mu bizdeki 2.4 sürümü zafiyetli aralıkta 3. açık ulaşılabilir mi makinenin uzak bakım modülü doğrudan internete açık olduğu için saldırgan erişebilir yani üç şart da uyduğu için cve bizi doğrudan etkiliyor

2 Üretimi hemen durdurur musunuz? Neden / neden değil?

hemen üretimi kapatmam çünkü makinada acil bir siber saldırı ya da sıcak çenede anormallik yoksa durdurmak paketi boşa harcar maliyet yaratır önce internete açık uzak bakım modülünün kablosunu çekerim veya portu kapatırım makine lokal paketlemeye devam eder yamayı da vardiya bitince test edip yükleriz

3 Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

çalışan hatta direkt yama atılmaz riskli olur önce yedek plc de ya da simülasyon ortamında denerim mevcut plc kodunun sıcaklık ve kesim ayarlarının yedeğini alırım üretici onayından sonra da mesai dışı bakım saatinde yükleriz

4 Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

eğer yama plc nin ışık perdesi kapak kilitleri ve sto ile haberleştiği fonksiyonları etkiliyorsa güvenlik validasyonu bozulur bunu üreticinin sürüm notlarından kontrol ederiz şüphe varsa yama sonrası ışık perdesini çene hareket ederken elimizle kesip çenenin anında durduğunu test ederiz

5 Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

yamayı kuramıyorsak uzak bakım cihazını internetten tamamen koparırız güvenlik duvarında portu kapatırız admin admin olan şifreyi karmaşık yaparız makineye usb takılmasını yasaklarız sadece iç ağdan vpn ile giriş bırakırız

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.